Ethical Hacking Assignment 1

ITA14 Ethical Hacking ASSIGNMENT 1

Name : Tamil Elakiya S

Reg No : 192524443

CO1

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment 1 Title : Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

Scenario — University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

TASK 1 – Formulate the Enquiry and Framework Blueprint (4 Marks)

- Convert the scenario into a formal set of engagement-governance requirements. Identify the systems in scope, the stakeholders, the expected activities and the constraints.
- Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure will cooperate in the proposed programme.
- Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.
- Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected

A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showing how the proposed framework addresses the scenario.

TASK 2 – Design a Hacker Threat Model and Classification (4 Marks)

- Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.
- Map each type to its motivation, typical capability and likely targets within the university.
- Establish clear criteria and naming so that an actor can be classified consistently.
- Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justify the final classification.

Evidence Expected

A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

TASK 3 – Create an Ethics and Code-of-Conduct Module (4 Marks)

- Define the ethical principles that govern an authorized engagement, such as written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.
- Design rules or checks that help detect or prevent unethical actions during an engagement.
- Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.
- Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected

A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

TASK 4 – Construct a Legal-Compliance Mapping (4 Marks)

- Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.

- Build a table of offences, obligations and penalties related to unauthorized access and data protection.
- Connect each legal requirement to a specific control in the engagement framework.
- Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected

A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

TASK 5 – Create a Scope and Rules-of-Engagement Document (4 Marks)

- Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths.
- Create rules for recording and verifying the written authorization behind each engagement.
- Establish clear naming and boundaries so that an out-of-scope request can be detected.
- Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected

A complete RoE document, authorization-verification rules, scope boundaries and a derived pre-engagement checklist.

TASK 6 – Build an Authorization and Disclosure Layer (5 Marks)

- Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.
- Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline, and compare it with full disclosure and bug-bounty approaches.
- Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.
- Create rules for choosing between coordinated and full disclosure for a given finding.
- Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

Evidence Expected

An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure rules and evidence of interaction with the other components.

TASK 7 – Design an Isolated Ethical-Hacking Lab (5 Marks)

- Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.
- Specify the components, roles and connectivity of the lab and the steps used to record its configuration.
- Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.
- Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.

- Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected

An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

TASK 8 – Develop a Reusable Document Library (4 Marks)

- Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.
- Use sensible default fields where appropriate and explicitly design the content of each document.
- At least one document, such as the finding report, must produce a structured output that integrates with another component of the framework.
- Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected

A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

TASK 9 – Integrate, Test and Refine the Framework (4 Marks)

- Integrate the components created in Tasks 2-8 into one coherent engagement framework.
- Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.
- Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.
- Record the problems encountered during the walkthrough and show how the framework was refined to address them.

Evidence Expected

A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

TASK 10 – Create a Scalability and Governance Evaluation (4 Marks)

- Construct scenarios representing a small programme (one department) and a large programme (the whole university with external assessors), with the number of systems and testers involved.
- Experiment with at least three important processes from the framework and record meaningful measures such as approval turnaround, scope coverage or the number of steps.
- Create a comparison table and at least one suitable chart or structured visualization.
- Use the evidence to refine the governance of the framework rather than simply reporting the measures.

Evidence Expected

A reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of at least one governance refinement based on the results.

TASK 11 – Defend the Framework Under a Changed Requirement (4 Marks)

- Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.
- Create a revised version of your framework by deciding which components should be retained, modified, replaced or redesigned.
- Construct at least one new or modified component that directly addresses the changed requirement and show how it integrates with the existing framework.
- Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.
- Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected

A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

MARK DISTRIBUTION

Task	**Marks**
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5
TASK 8 – Develop	4
TASK 9 – Integrate,	4
TASK 10 – Create	4
TASK 11 – Defend	4
TOTAL	50

ANSWERS

TASK 1 – Formulate the Enquiry and Framework Blueprint

1.1 Engagement-governance requirements. The scenario is converted into the following formal requirements.

Element	Requirement derived from the scenario
Systems in scope (about 20 initially)	Student portal, learning-management system (LMS), university email service and the campus-network segment hosting them. Each is registered in an asset inventory with a unique asset ID and tagged IN-SCOPE or OUT-OF-SCOPE. The inventory must be extendable to the whole university.
Stakeholders	University management / CISO (accountable owner of the programme); department heads (requesters); system owners (approve testing of their systems); internal testers; external third-party assessors; Data-Protection Officer (DPO); legal counsel; students and staff as data subjects.
Expected activities	Reconnaissance, scanning and enumeration of authorized assets; controlled hands-on testing only inside an isolated lab; documentation of findings; responsible disclosure and verification of remediation. No live exploitation of production systems.
Constraints	Systems hold personal data; written authorization is mandatory; limited testing windows to protect live services; the framework must scale from 20 systems to the whole university and must stay usable for external assessors; all work stays at design, documentation and isolated-lab level.

1.2 Framework blueprint. The parts cooperate as a chain, with a governance layer that records and audits every step:

Stage	Component	Input	Output / hand-off
1	Authorization	Test request from a department	Signed approval and a unique Engagement ID
2	Scope and Rules of Engagement (RoE)	Engagement ID, asset inventory	Tagged in-scope asset list, windows, permitted and prohibited techniques
3	Legal-compliance check	Scope list, data classification	Applicable laws, DPO decision, data-handling controls
4	Hacker threat model	Scope list, asset value	Attacker types to emulate and tester conduct level
5	Isolated-lab testing	Approved RoE and threat model	Evidence of weaknesses, produced only on lab targets
6	Finding report	Lab evidence	Structured finding record (ID, asset, severity, status)
7	Responsible disclosure	Finding record, legal result, RoE	Private report to the owner, remediation window, closure

The governance layer (CISO office) logs each hand-off, audits records, and feeds lessons from findings back into scope definition and scalability review. A request cannot move to the next stage unless the previous gate has passed.

1.3 Enquiry questions the framework must answer.

- Q1. Who authorizes a test, and how is that authorization recorded and verified?
- Q2. What systems are in scope and out of scope for a given engagement, and how is an out-of-scope request detected?
- Q3. Which laws apply, especially when a test touches systems that hold personal data?
- Q4. How are discovered vulnerabilities disclosed, to whom, and within what timeline?
- Q5. Who may perform tests (internal staff or external assessors) and under what conditions?
- Q6. How is hands-on testing kept away from live systems?

1.4 Design (acceptance) criteria. The final framework is accepted only if it satisfies all of the following.

ID	Criterion	How it is checked
C1	Every engagement has verifiable written authorization before any activity.	Test case: a request with no signed form is rejected.
C2	Scope is explicit, tagged and machine-checkable so out-of-scope requests are detected.	Test case: an untagged asset is rejected automatically.
C3	Each legal requirement is mapped to a concrete control.	Task 4 mapping has no requirement without a control.
C4	No harm to live systems; hands-on testing is confined to an isolated lab.	Lab has no route to the internet or production.
C5	Responsible disclosure with a defined report format and timeline.	Every finding has a due date computed from the report date.
C6	Scalable to the whole university and to external assessors, with auditable records.	Task 10 measures; every action has a log entry.

1.5 Rationale. The scenario's main risks are unauthorized access, legal exposure, damage to live systems, unclear scope and uncoordinated disclosure. Each risk is closed by one gate: authorization closes unauthorized access, the RoE closes unclear scope, the legal check closes legal exposure, the isolated lab closes damage to live systems, and the disclosure layer closes uncoordinated disclosure. Because the gates are sequential and logged, the framework works the same way for 20 systems or 200, and for internal or external testers.

TASK 2 – Design a Hacker Threat Model and Classification

2.1 Classification criteria and naming. Every actor is scored on four attributes, and the type name follows from the combination.

Attribute	Values	Question asked
A – Authorization	Yes / No	Does the actor hold written authorization for this target?
I – Intent	Benign / Mixed / Malicious	What is the actor trying to achieve?
S – Skill	Low / Medium / High / Very high	What capability and resources does the actor show?
F – Affiliation	External / Internal / Nation-backed	What is the actor's relationship to the university?

Naming rule: Type = f(A, I, S, F). Authorized and benign gives White-hat. Unauthorized and malicious gives Black-hat (or Hacktivist when the motive is political, Insider when F is internal, State-sponsored when F is nation-backed). Unauthorized and benign gives Grey-hat. Low skill with ready-made tools gives Script kiddie. Applying the attributes in this fixed order gives the same label whoever classifies.

2.2 Threat-model mapping table.

Type	Motivation	Typical capability	Likely university targets	A / I / S / F
White-hat	Improve security under authorization	High; disciplined, scoped	In-scope systems under signed engagement	Yes / Benign / High / Int. or Ext.
Black-hat	Financial gain, damage, theft	High; malicious	Student records, email credentials, fee data	No / Malicious / High / Ext.
Grey-hat	Curiosity, recognition; acts without permission	Medium to high	Student portal, exposed web services	No / Benign or Mixed / Med-High / Ext.
Script kiddie	Thrill, bragging	Low; uses ready-made tools	Any easy, exposed target	No / Mixed / Low / Ext.
Hacktivist	Political or social message	Medium	Public website (defacement), campaign pages	No / Malicious (ideological) / Med / Ext.
Insider	Grievance or personal gain; already has access	Medium; trusted access	HR, finance and examination data, internal apps	No (misuse) / Malicious / Med / Int.
State-sponsored	Espionage, strategic advantage	Very high; stealthy and persistent	Research data, sensitive records, network backbone	No / Malicious / Very high / Nation

2.3 Use in the framework. White-hat conduct is the standard that internal and external testers must meet. The other six types define the threats that the authorized tests emulate: for example, tests of the student portal emulate a grey-hat or script-kiddie style attacker, tests of internal applications emulate an insider, and tests of research systems emulate a state-sponsored actor (in design only, never live).

2.4 Borderline actor. A student finds a flaw in the student portal without permission, uses a public scanner to confirm it, and reports it to the IT office.

Option	Classification	Reasoning	Verdict
Alternative A	Script kiddie	Used a ready-made tool and shows low skill.	Rejected: skill alone does not define the type; the student acted to report, not for thrill or damage, and understood the flaw well enough to explain it.
Alternative B	Black-hat	Accessed a system without authorization, which is an offence.	Rejected: intent was not malicious, no data was taken and no payment was demanded.
Chosen	Grey-hat	A = No, I = Benign, reported the issue.	Accepted: the defining attributes (no authorization, non-malicious intent) match exactly.

Final classification: Grey-hat. Justification: the classification rule gives priority to authorization and intent over skill. The actor has no authorization (so not white-hat) and no malicious intent (so not black-hat). If the student had demanded payment or kept the data, intent would become malicious and the classification would move to black-hat. Even as a grey-hat, the act was unauthorized, so the programme responds with a safe-reporting channel and not with an assumption of innocence.

TASK 3 – Create an Ethics and Code-of-Conduct Module

3.1 Ethical principles.

No.	Principle	Meaning in practice
P1	Written authorization	No activity begins without a signed authorization carrying an Engagement ID.
P2	Agreed scope	Only assets tagged in-scope are touched, only in the agreed window.
P3	Confidentiality	Findings, credentials and any data seen are shared only with the named owner.
P4	Integrity of evidence	Evidence is not altered, fabricated or deleted; logs are complete.
P5	Avoiding harm	No denial of service, no data loss, no disruption to live services.
P6	Honest and complete reporting	All findings are reported accurately, including the tester's own mistakes.

No.	Principle	Meaning in practice
P7	Least intrusion and data minimisation	Use the lightest technique that proves the point and never copy personal data.

3.2 Rules and checks that prevent or detect unethical action.

- R1 Authorization gate: no Engagement ID means no action (prevent).
- R2 Scope check before each action: a target outside the tagged scope is blocked and reported (prevent).
- R3 Mandatory action log: each scan, command and result is time-stamped and attributable to a named tester (detect).
- R4 Dual control: sensitive steps (any test touching a system with personal data, any use of credentials) need a second person's approval (prevent).
- R5 Stop-and-report: if personal data or an unexpected system is encountered, the tester stops, makes no copy, and informs governance within one hour (prevent).
- R6 Post-engagement log review by someone who did not take part in the test (detect).

3.3 Decision rule. For any proposed action: if no valid authorization or the target is out of scope, the class is Unacceptable or Borderline by R1/R2. If the action may expose personal data, use stolen or found credentials, or cause service impact, it is Unacceptable. If the situation is unclear, treat as Borderline: stop, do not test, and ask governance. Only actions that pass R1 to R5 are Acceptable.

3.4 Scenario test cases.

Case	Action	Class	Code-of-conduct response
S1	Scan an in-scope LMS server during the agreed window, with a signed form.	Acceptable	Proceed; log the activity.
S2	During scanning, the tester notices that a staff-payroll server is reachable but not in scope.	Borderline	Stop, do not test it, report to governance for a scope decision (R2, R5).
S3	Tester wants to confirm a finding by running a heavy scan on the live portal at peak hours.	Borderline	Not allowed outside the window; request a window change or reproduce in the lab.
S4	Using found credentials to log in to another system, or copying a student-records file as proof.	Unacceptable	Prohibited; halt engagement, escalate to CISO and DPO, preserve evidence.
S5	Tester deletes log lines showing an accidental out-of-scope ping.	Unacceptable	Violation of P4/P6; engagement suspended and investigated.
S6	An external assessor brings a colleague who has no authorization.	Unacceptable	Access refused; only named, vetted testers listed on the form may take part.

3.5 Evidence that the rules separate the classes. The six cases above are decided by the same four tests: authorization, scope, harm and personal data. S1 passes all four (Acceptable), S2 and S3 fail only scope or window and are recoverable by a governance decision (Borderline), and S4 to S6 fail integrity, harm or data protection and cannot be recovered by approval (Unacceptable). The result is repeatable, so two different reviewers reach the same class.

3.6 Trust and lawfulness. Every action is authorized, accountable (logged), lawful (the legal rules in Task 4 are built into R4 and R5) and professional (honest reporting). This protects the university from legal exposure and the tester from accusations of misuse, which is why external assessors can be trusted with the same rules as internal staff.

TASK 4 – Construct a Legal-Compliance Mapping

4.1 Offences, obligations and penalties (IT Act, 2000 compared with the US CFAA). Penalties are indicative summaries for the purposes of this design; counsel should confirm current text before use.

Offence / obligation	IT Act, 2000 (India)	CFAA (US) equivalent	Indicative penalty
Unauthorized access to a computer or network, damage, data extraction	Sec 43	18 U.S.C. §1030(a)(2), (a)(5)	IT Act: compensation to the affected party. CFAA: fine and/or imprisonment (generally up to 1 year, higher for aggravated cases)
Computer-related offence done dishonestly or fraudulently (hacking)	Sec 66 (read with Sec 43)	§1030(a)(4) (access with intent to defraud)	IT Act: up to 3 years and/or fine up to Rs 5 lakh. CFAA: up to 5 years for a first offence
Identity theft and cheating by personation using a computer	Sec 66C, 66D	§1028, §1030	IT Act: up to 3 years and fine up to Rs 1 lakh
Breach of confidentiality and privacy; disclosure in breach of a lawful contract	Sec 72, 72A	No direct equivalent (state and sector privacy laws)	Sec 72: up to 2 years and/or fine up to Rs 1 lakh. Sec 72A: up to 3 years and/or fine up to Rs 5 lakh
Failure to protect sensitive personal data by a body corporate	Sec 43A (with SPDI Rules 2011)	No direct equivalent	Compensation to the person affected
Personal-data security safeguards and breach notification	Digital Personal Data Protection Act, 2023	No direct equivalent	Financial penalties set by the Act (up to Rs 250 crore for failing to maintain security safeguards)

Offence / obligation	IT Act, 2000 (India)	CFAA (US) equivalent	Indicative penalty
Incident reporting	Sec 70B and CERT-In Directions (2022)	Sector-specific reporting	Reporting to CERT-In of specified incidents within 6 hours

4.2 Each legal requirement linked to a control.

Legal requirement	Framework control	Where it lives
Sec 43 / 66 / CFAA (no unauthorized access)	Mandatory written authorization sign-off; no Engagement ID means no test; scope enforced by asset tags	Task 5, Task 6 (workflow)
Sec 66C / 66D (credential misuse)	Code of conduct R4: found credentials may not be used; any use needs dual approval	Task 3
Sec 43A / 72 / 72A (confidentiality, personal data)	Data-handling policy: minimisation, no exfiltration, encrypted evidence storage, private disclosure only	Task 3, Task 6
DPDP Act 2023 (safeguards, purpose limitation)	DPO approval before any test touching personal data; test data masked or synthetic in the lab	Task 5, Task 7
Sec 70B / CERT-In (incident reporting)	Escalation path: if a real breach is found, report to the CISO, who reports to CERT-In within the required time	Task 5 (escalation), Task 6
Contractual duty to the system owner	Disclosure only to the authorized owner, in the agreed format and window	Task 6

4.3 Comparison with the CFAA. Both laws turn on the same idea: access that is not authorized, or that exceeds authorization, is an offence. This is why the framework treats the signed authorization and the scope boundary as the most important controls. The IT Act additionally contains explicit provisions on data protection (Sec 43A, 72, 72A) and is now supplemented by the DPDP Act 2023, whereas the CFAA has no general personal-data rule. Because external assessors may be foreign nationals or foreign firms, the contract also states that CFAA-style limits (never exceed authorized access) apply to them regardless of location.

4.4 Which laws apply when a test touches personal data. Decision: when a system holds personal data, the IT Act Sec 43 and 66 (unauthorized access) continue to apply, and Sec 43A, Sec 72/72A and the DPDP Act 2023 apply in addition. The engagement therefore needs DPO approval, explicit data-handling rules and the strictest controls. Justification: personal data creates two liabilities at once (unauthorized access and data-protection breach), and when two regimes overlap the stricter one governs. The CFAA is referenced only as a benchmark and as a contractual standard for foreign assessors; it is not the governing law for the university's Indian systems.

TASK 5 – Create a Scope and Rules-of-Engagement Document

5.1 Scope and Rules-of-Engagement document (template with default values).

Section	Content
Engagement ID	ENG-YYYY-NNN (issued only after sign-off)
In-scope systems	Student portal (UNI-PRT-001), LMS (UNI-LMS-001), email service (UNI-EML-001), campus-network segment 10.x.x.0/24 as listed by asset ID. Only assets tagged IN-SCOPE in the inventory and named on the form.
Out-of-scope systems	Production databases holding live personal data (unless separately authorized with DPO approval); third-party hosted services; payroll and finance systems; any asset not explicitly tagged in scope.
Testing window	Off-peak hours agreed with system owners (default 22:00 to 05:00 IST, weekdays); no testing during examinations or admissions.
Permitted techniques	Passive reconnaissance, authenticated and unauthenticated scanning at agreed rate, enumeration, configuration review, and exploitation only against lab replicas in the isolated lab.
Prohibited techniques	Denial-of-service, social engineering of real staff or students (without separate authorization), data exfiltration, password cracking of real accounts, persistence or backdoors, pivoting to any other system, and any out-of-scope testing.
Escalation paths	Level 1: named contact of system owner (24x7 phone). Level 2: CISO. Emergency stop: any party may say STOP; the tester halts within 5 minutes and confirms by e-mail. Real incident found: CISO, then CERT-In as required.
Data handling	No personal data is copied; screenshots are masked; evidence is stored encrypted and deleted at closure per the retention rule.
Communication	Status update every working day; findings sent only through the approved channel.

5.2 Authorization recording and verification rules.

- V1 Each engagement has one signed authorization form with a unique Engagement ID, entered in the engagement register.
- V2 Signatories: requesting department head, owner of each system, and the CISO; for personal-data systems the DPO also signs.
- V3 The register verifies that signatories hold the role at the date of signing and that the dates and Engagement ID are valid.
- V4 Authorization expires on the stated end date; extension needs a new signature.
- V5 Testers must show the Engagement ID at the start of each session; no ID, no test.
- V6 Scans and logs are labelled with the Engagement ID so every action can be traced to an authorization.

5.3 Naming and boundaries to detect out-of-scope requests. Every asset has an ID of the form UNI-<TYPE>-<NNN> and carries a tag (IN-SCOPE / OUT-OF-SCOPE / RESTRICTED) in the asset inventory. A request is accepted only if every target (ID, IP address or hostname) matches an asset tagged IN-SCOPE for that Engagement ID. Anything else is rejected automatically and logged as an out-of-scope attempt. Wildcards (for example, a whole subnet) are not accepted; targets are listed individually.

5.4 Transformation of the RoE into a pre-engagement checklist. Each RoE section becomes a yes/no check that must be ticked before testing starts.

Tick	Check (derived from RoE section)
☐	Written authorization signed and verified; Engagement ID issued (V1 to V4)
☐	Every target matched against the asset inventory and tagged IN-SCOPE (5.3)
☐	Testing window agreed with system owners
☐	Contacts, escalation path and emergency-stop procedure confirmed
☐	Permitted and prohibited techniques briefed to every tester
☐	Isolated lab ready and configuration recorded
☐	Legal and data-protection check done; DPO approval where personal data is involved
☐	Data-handling and evidence-storage rules agreed

TASK 6 – Build an Authorization and Disclosure Layer

6.1 Authorization workflow.

Step	Action	Owner	Output
1 Request	Department submits request: systems, purpose, dates, testers	Department head	Request record
2 Review	Scope checked against inventory; legal and data-protection review	Governance team, legal, DPO	Review note; scope list
3 Approval	System owners and CISO approve; DPO approves if personal data	System owner, CISO, DPO	Approvals
4 Written sign-off	Authorization form signed by all required signatories	All signatories	Signed form
5 Record	Engagement ID issued and entered in register with scope and dates	Governance team	Register entry
6 Execute	Testing under RoE; daily status updates	Testers	Logs, findings
7 Close	Findings disclosed, remediation verified, evidence deleted per policy	Governance team	Closure record

6.2 Responsible (coordinated) disclosure process.

Element	Definition
Reporting format	Finding ID, Engagement ID, title, affected asset ID, description, severity (CVSS score and vector), evidence (masked), steps to reproduce (lab), recommended remediation, reporter, report date.
Recipient	Only the authorized system owner and the CISO (never a third party, never public).
Remediation window	90 days from report date; 30 days for critical findings (CVSS 9.0 and above). Timeline starts on the report date.
Status flow	Reported, Acknowledged (within 2 working days), In remediation, Fix verified, Closed (or Escalated if the window lapses).
Extension	One extension of up to 30 days by the CISO with written reason; recorded in the log.

6.3 Comparison of disclosure approaches.

Aspect	Coordinated (chosen default)	Full disclosure	Bug bounty
How it works	Private report to owner; public details only after fix or window	Details published immediately	Pre-authorized researchers report within a published programme and are paid
Benefit	Time to fix before attackers learn of it	Forces quick action	Wide researcher pool, clear rules
Risk	Owner may delay (handled by deadline)	Exposes users before a fix exists	Only valid in published scope; needs budget and triage staff
Fit for the university	Best for a university with personal data	Only as last resort	Possible future option for public-facing sites

6.4 Logging and decision operations.

Operation	Purpose	Rule / logic
logApproval(engID, role, name, date, decision)	Record each approval and sign-off	Append-only; rejects a role that is not required or a date after expiry; one entry per signatory
updateStatus(findingID, status, note)	Track a finding from Reported to Closed	Allowed transitions only in the status flow; each update time-stamped with user

Operation	Purpose	Rule / logic
canDisclose(finding)	Decide whether disclosure may proceed	Returns TRUE only if: asset is in scope of the engagement; owner has been notified; and (fix verified OR window elapsed OR owner agrees); and not blocked by personal-data rule

Pseudo-logic: canDisclose(f) = inScope(f) AND ownerNotified(f) AND (fixVerified(f) OR windowElapsed(f) OR ownerAgrees(f)) AND NOT(f.personalData AND mode == PUBLIC).

6.5 Rules for choosing coordinated or full disclosure.

- Default is coordinated disclosure for every finding.
- Move to limited public disclosure only if all hold: the window (including any extension) has lapsed, the risk to users is high, no personal data is exposed, and the CISO has recorded the decision.
- Findings involving personal data are never published; they stay private and are reported to CERT-In as required.
- Findings in third-party systems are reported to that vendor through the owner, not published.

6.6 Interaction with RoE and legal compliance. (a) RoE: a finding is accepted into the disclosure layer only if its asset ID is tagged IN-SCOPE for the Engagement ID, and the recipient is the owner named in the RoE. (b) Legal compliance: the legal result flag personalData=TRUE forces private-only handling and CERT-In reporting. (c) Authorization: updateStatus refuses to work on a finding whose Engagement ID is not in the register. Example: a finding on UNI-PRT-001 with personal data exposed returns canDisclose = FALSE for PUBLIC mode even after 90 days, showing that the layer obeys the other components and does not act alone.

TASK 7 – Design an Isolated Ethical-Hacking Lab

7.1 Lab design and specification. The lab runs on one host computer in a hypervisor (for example VirtualBox). All machines are virtual and connect to one host-only network with no gateway.

Component	Role	Address	Connectivity
Host-only virtual switch	Isolated internal network	192.168.56.0/24 (no gateway)	Only the lab VMs and the host's virtual adapter
Kali Linux VM	Attacker / tester workstation	192.168.56.10	Reaches target VMs only
Target VM 1 (DVWA)	Authorized vulnerable web target (replica of a portal-type application)	192.168.56.20	Reachable from Kali only

Component	Role	Address	Connectivity
Target VM 2 (Metasploitable, optional)	Authorized vulnerable server for network-service practice	192.168.56.21	Reachable from Kali only
Host machine	Runs hypervisor; holds the lab-config record	192.168.56.1 (virtual adapter)	No routing between the host-only adapter and any physical network

Safeguards: the NAT and bridged adapters are disabled on all VMs; IP forwarding is off on the host; targets contain only synthetic data and never a copy of real student records; snapshots are taken before and after each session.

7.2 Operations.

Operation	Steps	Expected result
Op1 Verify connectivity and isolation	From Kali: ping -c 4 192.168.56.20; then ip route and ping -c 2 8.8.8.8; then ping a production address	Replies from 192.168.56.20; no default route; internet and production pings fail (100% loss)
Op2 Record the lab configuration	On Kali: ip a and ip route > lab-config-DATE.txt; nmap -sV 192.168.56.20 >> lab-config-DATE.txt; add hypervisor network name, VM snapshot name, Engagement ID, tester name, and a SHA-256 hash of the file	One dated, hashed lab-config file stored with the engagement record
Op3 Reset lab	Restore the clean snapshot of each VM and repeat Op1	Lab returns to known-good state before the next engagement

7.3 Host-only versus NAT.

Aspect	Host-only (chosen)	NAT
Internet access	None; fully isolated	Yes, through the host
Risk of leakage	Very low; traffic cannot leave	Higher; scans or malware can reach outside networks
Visibility between VMs	Yes, VMs see each other and the host	VMs do not see each other unless a NAT network is used
Updating tools	Done by temporarily using a snapshot or offline packages	Easy, but breaks isolation
Suitability	Safe, contained, authorized testing	Convenient but less safe

7.4 Justification and containment. Host-only is chosen because it keeps all testing authorized and contained: the only reachable hosts are the authorized targets, so nothing can escape to production or the internet, and an error such as a mistyped IP address cannot reach a real system. The lab is tied to the framework: a lab session may begin only when the pre-engagement checklist (Task 5) is complete and the Engagement ID is recorded in the lab-config file, so every command in the lab is traceable to an authorization. The trade-off is that updating tools requires a separate, controlled step (offline packages or a temporary, approved update snapshot), which is accepted for the gain in safety.

TASK 8 – Develop a Reusable Document Library

8.1 Document library (five reusable documents).

Document	Fields (defaults in brackets)
D1 Authorization Form	Engagement ID (auto: ENG-YYYY-NNN); requester name and department; purpose; systems by asset ID; start and end date; testers (internal / external, vetted Y/N); personal data involved Y/N; signatures: department head, system owner(s), CISO, DPO (if personal data); date signed; status [Draft]
D2 Scope / RoE Form	Engagement ID; in-scope asset IDs; out-of-scope assets; testing window [22:00 to 05:00 IST]; permitted techniques [recon, scan, enumeration, lab exploitation]; prohibited techniques [DoS, social engineering, exfiltration]; escalation contacts; emergency-stop contact
D3 Finding Report	Finding ID (FND-NNN); Engagement ID; asset ID; title; description; severity [CVSS score and rating]; evidence reference (masked); reproduction steps (lab); remediation advice; personal data involved [No]; report date; status [Reported]
D4 Disclosure Record	Finding ID; recipient (owner); report date; window [90 days; 30 if critical]; due date (computed); extension Y/N and reason; status; closure date; verification note
D5 Pre-engagement Checklist	Engagement ID; eight checks from Task 5 with tick, name and date; final go / no-go signature by governance lead

8.2 Structured output and integration. The Finding Report (D3) emits a structured record that is read by other components:

{ "findingID": "FND-001", "engagementID": "ENG-2026-007", "asset": "UNI-PRT-001", "severity": "High", "cvss": 8.1, "personalData": false, "reportDate": "2026-11-10", "status": "Reported" }

The disclosure layer (Task 6) consumes this record to create the Disclosure Record D4 and compute the due date (report date plus 90 days, or plus 30 if the severity is Critical). The scalability evaluation (Task 10) counts the records by severity, status and turnaround. The scope check (Task 5) reads the asset field, and the legal check reads personalData.

8.3 Test entries.

No.	Input	Type	Expected result
T1	Authorization form with all fields and all required signatures	Valid	Accepted; Engagement ID issued
T2	Finding report with CVSS 8.1, in-scope asset, status Reported	Valid	Accepted; disclosure record created with due date = report date + 90 days
T3	Authorization form missing the DPO signature, personal data = Yes	Boundary	Flagged; cannot start until completed
T4	Finding with CVSS exactly 9.0	Boundary	Classified Critical; window 30 days
T5	Authorization form whose end date is before the start date	Boundary	Rejected with error message; must be corrected
T6	Test request with no authorization form	Invalid	Rejected automatically; logged
T7	Finding report for an asset not tagged IN-SCOPE	Invalid	Rejected; reported to governance as out-of-scope
T8	Finding report with CVSS 12	Invalid	Rejected; CVSS must be 0.0 to 10.0

TASK 9 – Integrate, Test and Refine the Framework

9.1 Integration of Tasks 2 to 8. The components form one chain: Authorization form D1 (Task 8) and workflow (Task 6) → RoE and scope check (Task 5) → legal check (Task 4) → threat model selects the attacker style to emulate (Task 2) → code of conduct applies during testing (Task 3) → isolated lab (Task 7) → Finding Report D3 (Task 8) → responsible disclosure (Task 6) → closure. The document library supplies every form, and the governance register records each hand-off.

9.2 Walkthrough: student-portal assessment.

Step	What happens	Component used	Record produced
1	The Computer Science department requests a test of the student portal (UNI-PRT-001) before the upgrade.	Authorization workflow	Request record
2	Governance reviews the request; the asset is IN-SCOPE; the legal check flags personal data, so DPO approval and stricter controls are added.	Scope/RoE, legal mapping	Review note; D2 completed
3	System owner, CISO and DPO sign D1; Engagement ID ENG-2026-007 is issued and logged by logApproval().	Authorization layer	Register entry

Step	What happens	Component used	Record produced
4	Threat model chosen: grey-hat / script-kiddie style attacker against a public portal. The checklist D5 is completed.	Threat model, checklist	D5
5	Two internal testers work in the isolated lab on a replica of the portal; Op1 and Op2 are run and logged.	Lab, code of conduct	Lab-config file; action log
6	An SQL-injection weakness is confirmed on the replica and written into Finding Report FND-001 (CVSS 8.1, High, masked evidence).	Finding report	D3 record
7	The disclosure layer opens D4: private report to the portal owner and CISO; due date 90 days; updateStatus() tracks acknowledgement.	Disclosure layer	D4 record
8	The owner fixes the weakness; the fix is verified on the lab replica; canDisclose() returns TRUE; the engagement is closed and evidence is deleted per policy.	Disclosure, lab	Closure record

9.3 Systematic test cases.

No.	Test case	Input	Expected framework behaviour
TC1	Missing authorization	Scan request, no Engagement ID	Engagement rejected before any activity; logged
TC2	Out-of-scope request	Target UNI-PAY-002 (payroll), tagged OUT-OF-SCOPE	Detected by asset tag and rejected; governance notified
TC3	Legal conflict	Test of a database with student records, no DPO approval	Blocked until DPO approval is obtained
TC4	Delayed disclosure	Finding unresolved on day 91	Escalation rule triggers CISO review; extension or limited disclosure decision recorded
TC5	Expired authorization	Test attempted after end date	Rejected; new signature required

9.4 Problems found and refinement.

Problem found in walkthrough or tests	Refinement made
Out-of-scope detection was initially manual, so a mistyped asset could pass.	Added an automatic asset-tag check against the inventory (TC2).

Problem found in walkthrough or tests	Refinement made
The disclosure window was ambiguous (when does the clock start; what about critical findings?).	Fixed the rule: clock starts on report date; 90 days, 30 days for critical; one extension only.
Personal-data findings could be published after the window.	canDisclose() now blocks public mode for any finding with personalData = TRUE.
Authorization could be used after expiry.	Added expiry check V4 and test TC5.

TASK 10 – Create a Scalability and Governance Evaluation

10.1 Scenarios. Small programme: one department, 5 systems, 2 internal testers. Large programme: whole university, about 200 systems, 20 internal and 10 external testers.

10.2 Evaluation setup (reproducible). This is a tabletop simulation of the workflow in Task 6, not a measurement of a live system. Assumptions: each approval step takes the signatory's queue time (small: about 1 hour per signatory with 3 signatories; large: about 6 hours per signatory with 5 to 6 signatories in sequence, including DPO and external-assessor vetting); scope coverage is the share of registered systems that were tested in the quarter, limited by tester-hours; disclosure steps count the hand-offs from finding to closure. Anyone can reproduce the figures by replaying the same step list with the stated queue times.

10.3 Process measures (comparison table).

Process	Small programme	Large programme (before refinement)	Large programme (after refinement)
Approval turnaround	about 4 hours	about 36 hours	about 12 hours
Scope coverage	100%	82%	95%
Disclosure steps	5	9	7

Small = 1 department, 5 systems, 2 testers. Large = university, 200 systems, 30 testers. The "after refinement" column is the projected result of the changes in 10.5 under the same assumptions.

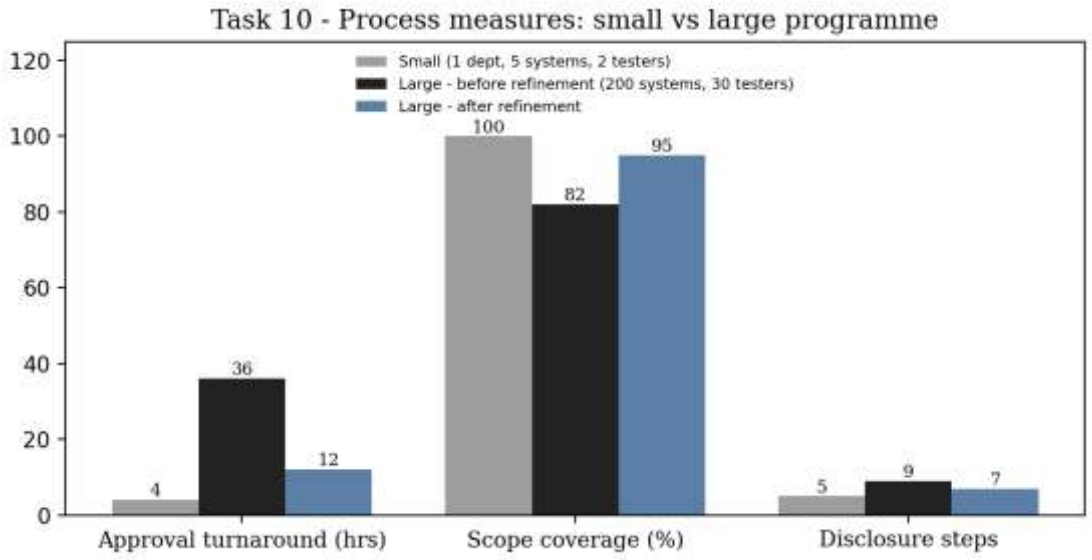


Figure 1: Process measures for small and large programmes, before and after refinement.

10.4 Interpretation. As the programme grows, approval turnaround rises roughly ninefold, coverage falls from 100% to 82%, and disclosure needs four more steps. The causes are sequential approvals through a few senior people, no way of prioritising which systems to test first when tester time is short, and extra hand-offs for external assessors. If left unchanged, the framework would still be safe but would slow down testing enough to leave the highest-risk systems untested.

10.5 Governance refinement made from the evidence.

- Delegated approval: department heads and system owners can approve low-risk engagements (no personal data, in-scope, standard RoE); the CISO and DPO approve only high-risk or personal-data engagements. This and parallel review (owner, legal and DPO review at the same time, not one after another) target the 36-hour turnaround.
- Standardised external-assessor onboarding: vetting and NDA are done once per assessor, and the approval record is reused for later engagements.
- Risk-based scheduling: systems are ranked by data sensitivity and exposure, and the highest-ranked are always scheduled first, so coverage losses fall on low-risk systems.
- Disclosure simplified to a template with automatic due-date calculation, removing two hand-offs.

TASK 11 – Defend the Framework Under a Changed Requirement

11.1 Revised framework: retain, modify, replace, redesign.

Decision	Component	Reason
Retain	Authorization workflow, RoE structure, asset tagging, isolated lab, code of conduct	Walkthrough (Task 9) showed they work end to end and they are independent of how often testing happens.

Decision	Component	Reason
Modify	Disclosure timeline: 30 days (7 days for critical)	Changed requirement asks for a shorter timeline; only the constants change because the window is a parameter.
Modify	Legal mapping: add DPDP Act 2023 duties (purpose limitation, safeguards, breach notification) as explicit controls; test data in the lab must be synthetic or masked	Stricter data-protection rules.
Modify	Hacker threat model: add a row for third-party assessor as an insider-like risk	External testers now have recurring access.
Replace	Manual approval logging (register file) with a workflow / ticketing tool with automatic time-stamps and audit trail	Task 10 showed manual approval does not scale; continuous testing needs an auditable system.
Redesign	One-off engagements become a continuous-assessment pipeline: a standing authorization per asset group, renewed periodically, with scheduled scans inside approved windows and change-triggered re-tests	Continuous assessment cannot use one signature per test.

11.2 New component: External-Assessor Governance Module. Contents: (1) vetting of assessors and individual testers (identity, references, conflict of interest); (2) signed NDA and data-protection agreement that names the DPDP duties; (3) scoped, least-privilege, time-limited access, with accounts created per engagement and removed at closure; (4) full audit of testers' actions through the Engagement-ID-labelled log; (5) the same code of conduct and RoE as internal staff.

Integration: the module plugs into the authorization workflow at the Review step (an assessor must be on the approved list before the request can be approved), into the RoE (assessor testers' names and access limits are listed), into the legal layer (the NDA satisfies the confidentiality controls), and into the disclosure layer (assessors send findings only to the owner and may not disclose independently). External testers are therefore governed exactly like internal ones.

11.3 Evidence-based defence.

Evidence	What it shows for the changed requirement
Walkthrough (Task 9)	The end-to-end chain works and every test case (missing authorization, out-of-scope, legal conflict, delay) is blocked or escalated; the same chain is reused in the pipeline.
Scalability evaluation (Task 10)	Delegated approval, parallel review and risk-based scheduling bring the large-programme turnaround from about 36 to about 12 hours and coverage from 82% to 95%, making continuous testing practical.
Legal mapping (Task 4)	Every requirement already has a control; DPDP Act duties are added as controls and personal-data engagements need DPO approval.

Evidence	What it shows for the changed requirement
Disclosure process (Task 6)	The window is a parameter, so shortening to 30 or 7 days is a configuration change; canDisclose() and the personal-data rule remain correct.

The framework stays easy to govern because the changes are confined to parameters (timeline), one added module (external assessors), one replaced tool (ticketing) and one redesigned flow (pipeline); the gates and the document library are unchanged. It stays easy to extend because new asset groups or new assessors are added by tagging and onboarding, not by rewriting rules.

11.4 Remaining trade-offs and limitations, and future improvements.

Trade-off / limitation	Future improvement
A shorter disclosure window (30 / 7 days) can pressure remediation teams and may cause rushed fixes.	Pair the window with remediation support and risk-based priority; allow one documented extension.
External assessors and continuous testing increase coordination and monitoring overhead.	Automate approvals, log monitoring and report generation; use risk-based scheduling.
The scalability figures come from a tabletop model, not live operation.	Re-measure after a pilot using real timestamps from the ticketing tool.
The lab uses replicas and synthetic data, so some production-specific weaknesses may not appear.	Add periodic authorized, read-only configuration reviews of production under DPO approval.